

Web Application Vulnerability Assessment – OWASP Juice Shop



Passive Security Review of OWASP Juice Shop

Program: Future Interns — Cyber Security Internship

Task: Task 1 — Vulnerability Assessment Report

Assessment Type: Passive / Read-Only

Target: OWASP Juice Shop — <http://localhost:3000>

1. Executive Summary

This report documents a passive security assessment of a locally hosted OWASP Juice Shop application.

The assessment was performed using Nmap, OWASP ZAP, and Chrome Developer Tools to review network exposure, HTTP communication, browser-side configuration, and potential security weaknesses.

The assessment identified configuration and security-hardening observations related to cross-origin access, HTTP caching, and browser-side data handling. Each observation was reviewed from a security perspective and accompanied by appropriate recommendations.

No exploitation, brute-force activity, denial-of-service testing, authentication bypass, or destructive testing was performed.

2. Assessment Objectives

The assessment aimed to:

- Identify accessible network services.
- Review the application's HTTP security configuration.
- Examine response headers and cross-origin behaviour.
- Inspect cookies and browser storage.
- Identify potential security configuration weaknesses.
- Assess the potential impact of observed issues.
- Classify findings according to risk.
- Provide practical remediation recommendations.

3. Scope

In Scope

- OWASP Juice Shop running locally
- TCP port and service reconnaissance
- HTTP response analysis
- OWASP ZAP passive analysis
- Browser security inspection
- Cookie configuration
- Browser storage
- Security-header review

Out of Scope

- SQL injection exploitation
- Cross-site scripting exploitation
- Authentication bypass
- Brute-force attacks
- Denial-of-service testing
- Privilege escalation
- Destructive or intrusive testing

4. Target Information

Parameter	Details
Application	OWASP Juice Shop

Host	localhost
IP Address	127.0.0.1
Port	3000
Protocol	HTTP
Target URL	http://localhost:3000

Assessment Mode Passive / Read-Only

OWASP Juice Shop is an intentionally vulnerable web application designed for security education and application-security testing.

5. Tools Used

Nmap

Used for basic network reconnaissance, port discovery, and service identification.

OWASP ZAP

Used in passive scanning mode to monitor application traffic and identify potential security configuration issues without actively exploiting the target.

Chrome Developer Tools

Used to inspect:

- Network requests
- HTTP response headers
- Cookies
- Local Storage
- Session Storage

- Client-side application behaviour

6. Assessment Methodology

The assessment followed the following process:

Target Identification



Nmap Reconnaissance



Application Browsing



OWASP ZAP Passive Analysis



Chrome DevTools Inspection



Evidence Collection



Finding Analysis



Risk Classification



Remediation Recommendations

The assessment was limited to passive observation and read-only analysis.

7. Network Reconnaissance

Nmap Scan

An Nmap service-detection scan was performed against the local application.

Command

```
nmap -sV -p 3000 localhost
```

Observation

The target host was reachable and **TCP port 3000 was open**.

Nmap returned application response data but did not positively identify the service using its standard service fingerprinting.

Security Interpretation

Port 3000 is the network endpoint used by the locally hosted Juice Shop instance.

For a local development environment, this exposure is expected. In a production deployment, only services required for normal application operation should be accessible.

Recommendation

Restrict externally accessible services and apply appropriate host-level firewall rules in production environments.

Evidence

```
Windows PowerShell X + -
```

```
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Users\rahul> nmap -cV -p 3000 localhost
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-25 22:06 +0530
Nmap scan report for localhost [127.0.0.1]
Host is up (0.0018s latency).
Other addresses for localhost (not scanned): ::1

PORT      STATE SERVICE VERSION
3000/tcp  open  ppp?
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
_
SF:Port3000-TCP/>V=7.99S1=74D7/725Kt1=6646E619MP=1686-p=windows-windosX
SF:r(GetRequest,2866,"HTTP/1.\1\x2020B\x20&K\r\nAccess-Control-Allow-Origin
SF:n:\x20*\r\nX-Content-Type-Options:\x20nosniff\r\nX-Frame-Options:\x20S
SF:AMEORIGIN\r\nFeature-Policy:\x20payment\x20self*\r\nX-Recruiting\x20B/
SF:Jobs\r\nLink-Ranges:\x20Buyers\r\nCache-Control:\x20public,\x20max-a
SF:ge=9\r\nLast-Modified:\x20Sat,\x2025\x20Jul\x202026\x2016:36:04\x20GMT/
SF:r\r\netag:"26af-19f9a2242b6"\r\nContent-Type:\x20text/html;\x20ch
SF:arset=UTF-8/\r\nContent-Length:\x2099985\x20Vary:\x20Accept-Encoding\r\n0
SF:State\x20at:\x201\x20Jul\x202026\x2016:36:41\x20GMT\r\nConnection:\x20
SF:close\r\n\r\n(\r\n-\r\n)\x20\x20-\x20Copyright\x20(\x20(c))\x202014-2026\x20Bjee
SF:rn\x20&inmicb\x20\x20&he\x20&w60P\r\nJuice\x20&osh\x20&nttributors\
SF:\n\x20\x20-\x20SPDX-License-Identifier:\x20MIT\r\n\x20\x20->\r\n<idotyp
SF:\x20html\r\nhtml\x20lang=\x20en">\x20data-seattlestiles-container\r\nhead>\n
SF:\x20<meta>\x20charset=\x20utf-8">\x20\x20\x20<title>=&ASP\x20Juice\x20&sh
SF:op</title>\r\n\x20<meta>\x20name="\x20description"/>\x20content="Probably
SF:\x20the\x20most\x20modern\x20and\x20sophisticated\x20insecure\x20web\x2
SF:&application">\r\n\x20<meta>\x20name="viewport"\x20content="width=
SF:device-width,height=device-height">\r\n\x20<link>\x20rel=\x20stylesheet
SF:"\x20href="http://k7help.2F","HTTP/1.\1\x20310B\x20&ad\x20&request\r\nConn
SF:ection:\x20close\r\n\r\n(CNP,2,2F,"HTTP/1.\1\x2010B\x20&ad\x20&request
SF:r\r\nConnection:\x20close\r\n\r\n">\x20HTTPOptions,E4,"HTTP/1.1\x2020dQ/x
SF:20W/\x20Content\r\nAccess-Control-Allow-Origin:(\x20*)\r\nAccess-Control
SF:Allow-Methods:\x20GET,HEAD,PUT,PATCH,POST,DELETE\r\nVary:\x20Access-Co
SF:ntrol-Request-Headers\r\nContent-Length:\x209\r\nNode:\x20Sat,\x2025\x2
SF:0Jul\x202026\x2016:36:41\x20GMT\r\nConnection:\x20close\r\n\r\n">\x2
SF:Prequest,E4,"HTTP/1.1\x2020dQ/x20BQ/x20&at\r\nAccess-Control-Allow-
SF:Origin:(\x20*)\r\nAccess-Control-Allow-Methods:\x20GET,HEAD,PUT,PATCH,PO
SF:ST,DELETE\r\nVary:\x20Access-Control-Request-Headers\r\nContent-Length:
SF:\x209\r\nNode:\x20Sat,\x2025\x20Jul\x202026\x2016:36:41\x20GMT\r\nConne
SF:ction:\x20close\r\n\r\n");

Service detection performed. Please report any incorrect results at https://nmap.org/submit/.
Nmap done: 1 IP address (1 host up) scanned in 12.30 seconds
PS C:\Users\rahul>
```

8. Browser Security Analysis

Chrome Developer Tools were used to review the application's browser-side behaviour.

The assessment focused on network communication, cookies, and browser storage.

Cookie Review

The application exposed the following cookies during the assessment:

- cookieconsent_status
- language

The observed cookies were associated with the local Juice Shop instance.

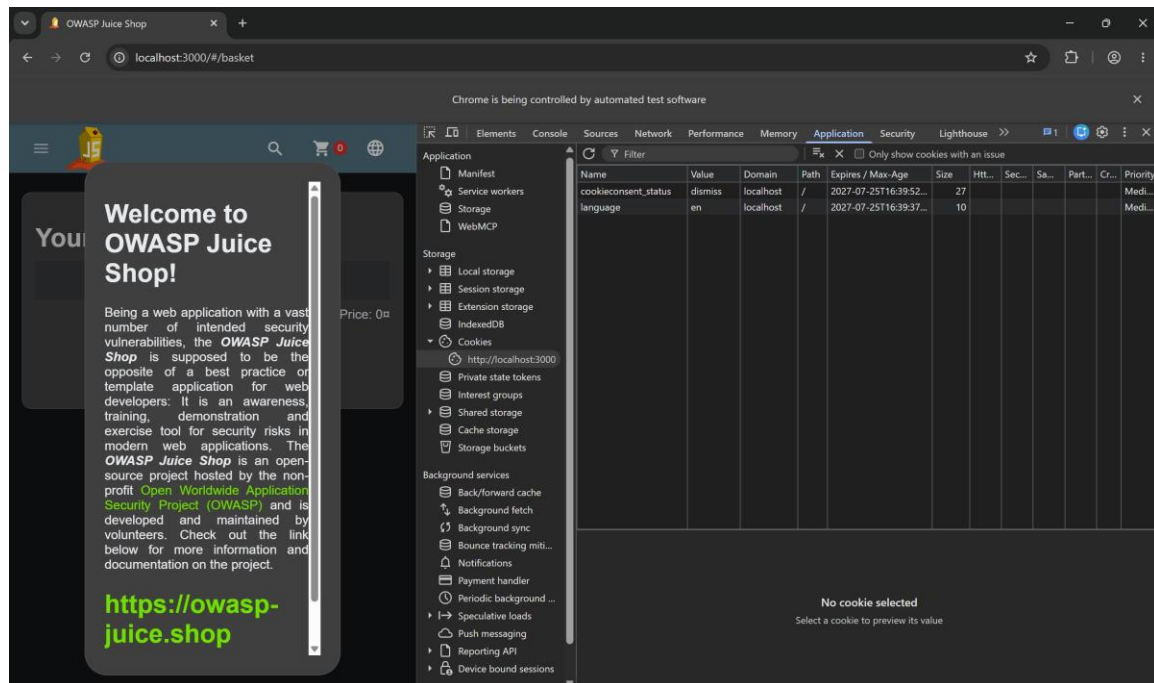
No conclusion regarding authentication-session security is made from these cookies alone because they do not represent a verified authentication/session cookie in the available evidence.

Security Consideration

Cookie attributes should be reviewed according to the purpose and sensitivity of the information being stored.

Where authentication or sensitive session information is handled, appropriate cookie protections such as Secure, HttpOnly, and suitable SameSite settings should be considered.

Evidence



9. Browser Storage Review

Browser storage was reviewed to determine whether application information was being retained on the client side.

Client-side storage can be accessed by JavaScript executing within the application's origin. Therefore, sensitive credentials, authentication tokens, or confidential information should not be unnecessarily stored in browser-accessible storage.

Recommendation

Review stored data and avoid placing sensitive information in Local Storage or Session Storage unless there is a justified requirement and appropriate security controls are in place.

10. OWASP ZAP Passive Analysis

OWASP ZAP was used to observe HTTP traffic generated while interacting with the Juice Shop application.

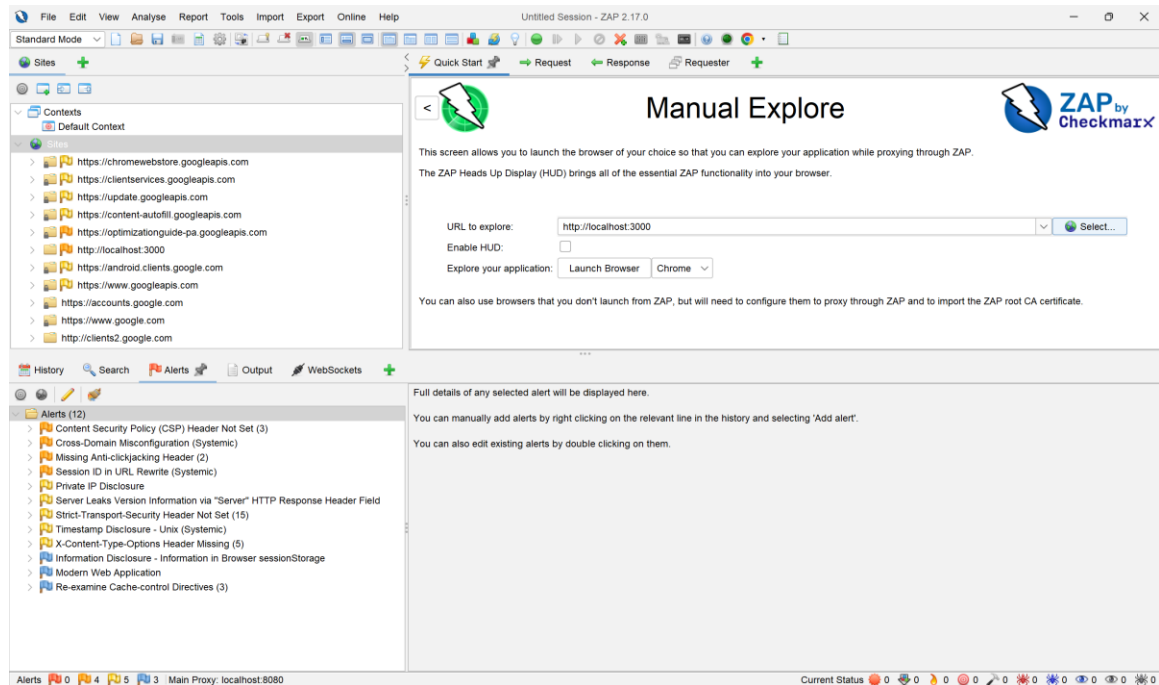
The scan was performed using **passive analysis**, meaning that the application was not actively attacked or exploited.

The passive analysis focused on:

- HTTP security headers
- Cross-origin configuration
- Caching behaviour
- Information exposure
- Other security-related response characteristics

The results were reviewed together with the corresponding HTTP responses before determining the relevance and severity of individual observations.

Evidence



11. Security Findings

Finding 01 — Permissive Cross-Origin Configuration

Severity: Medium

Observation

The HTTP response observed during the assessment included:

Access-Control-Allow-Origin: *

This configuration permits requests from arbitrary origins for resources where the header is applied.

Potential Impact

A wildcard cross-origin policy may increase exposure if applied to resources containing sensitive or user-specific information.

The actual impact depends on the resources affected and whether credentials or sensitive information can be accessed cross-origin.

Recommendation

Review the application's CORS configuration and restrict permitted origins to trusted domains where possible.

Avoid using a wildcard origin for sensitive resources.

Evidence

HTTP response information collected during the assessment.

Finding 02 — HTTP Security Header Hardening

Severity: Informational

Observation

The assessment included a review of HTTP security headers returned by the application.

The available evidence confirms that some security headers are already present, including:

X-Frame-Options: SAMEORIGIN

X-Content-Type-Options: nosniff

Therefore, these headers are **not reported as missing vulnerabilities**.

Recommendation

Maintain the existing protections and periodically review the complete set of security headers against the application's deployment requirements.

Where appropriate, consider additional controls such as Content Security Policy and other modern browser security mechanisms.

Evidence

Nmap HTTP response fingerprint and browser/network inspection.

Finding 03 — Cache-Control Configuration Review

Severity: Informational

Observation

The HTTP response included a cache directive similar to:

Cache-Control: public, max-age=0

The directive indicates that the response is marked as publicly cacheable while specifying a zero maximum age.

Potential Impact

The security impact depends on the type of content returned by the response.

Responses containing sensitive or user-specific information should be carefully controlled to prevent unintended caching.

Recommendation

Review cache directives for authenticated and sensitive responses and apply appropriate Cache-Control policies based on the content.

Evidence

HTTP response fingerprint collected during the assessment.

Finding 04 — Browser-Side Storage Review

Severity: Informational

Observation

Browser storage and cookies were inspected during the assessment.

The observed cookie entries included:

- cookieconsent_status
- language

Potential Impact

The presence of browser-side storage is not inherently a vulnerability. Risk depends on the sensitivity of the information stored and how it is accessed by application scripts.

Recommendation

Avoid storing sensitive credentials, authentication tokens, or confidential information in browser-accessible storage unless necessary.

Review client-side data handling as part of application security testing.

Evidence

Chrome Developer Tools Application panel.

12. Risk Summary

Severity	Count
High	0
Medium	1
Low	0
Informational	3

Priority

The cross-origin configuration should receive the highest priority for review because its impact depends on the resources to which the wildcard policy applies.

The remaining observations are primarily security-hardening considerations.

13. Security Recommendations

The following improvements are recommended:

1. Review and restrict the application's CORS configuration.
2. Maintain existing X-Frame-Options and X-Content-Type-Options protections.
3. Review HTTP security headers periodically.
4. Apply appropriate caching policies to sensitive responses.
5. Avoid storing sensitive information in browser-accessible storage.
6. Review cookie attributes for authentication and sensitive session cookies.
7. Restrict unnecessary network exposure in production deployments.
8. Keep application dependencies and security configurations updated.
9. Perform periodic vulnerability assessments after significant application changes.

14. Limitations

This assessment was performed against a **locally hosted OWASP Juice Shop** instance and was limited to passive and read-only techniques.

The assessment did not attempt to exploit identified weaknesses or determine whether individual observations could be chained into a successful attack.

Consequently, the results should be interpreted within the defined scope and methodology and should not be considered a complete penetration test.

15. Conclusion

The passive assessment provided an overview of the security configuration and browser-side behaviour of the locally hosted OWASP Juice Shop application.

Nmap was used to establish network exposure, while OWASP ZAP and Chrome Developer Tools provided additional visibility into HTTP communication and client-side behaviour.

The assessment identified a potentially permissive cross-origin configuration together with several security-hardening observations. The results demonstrate the importance of reviewing HTTP configuration, browser-side data handling, and network exposure as part of a broader web application security assessment.

16. References

- OWASP Juice Shop
- OWASP Web Security Testing Guide
- OWASP ZAP Documentation
- Nmap Documentation